

Security & Access Document

AssetFlow AI

Security & Access Specification

****Version:** 1.0**

Table of Contents

1. Authentication
2. User Roles
3. Permissions
4. Authorization Matrix
5. Row-Level Security
6. Password Policy
7. Session Management
8. API Security
9. Database Security
10. Error Handling
11. Edge Cases
12. Audit Logs
13. Future Security Enhancements

1. Authentication

Authentication Method

The application uses **JWT (JSON Web Token)** based authentication.

Login Methods

- Email + Password
- Google OAuth (Optional)
- Forgot Password via Email

Login Flow

```text

User Opens App



Login Screen



Enter Email & Password



Server Validates Credentials



JWT Generated



User Redirected to Dashboard

```

JWT Configuration

Access Token

- Expiry: 24 Hours

Refresh Token

- Expiry: 7 Days

Stored In

- HttpOnly Cookie (Preferred)
- Local Storage (Development)

2. User Roles

There are four primary roles.

Admin

Full system access.

Responsibilities

- Manage users
- Manage assets
- Assign assets
- View reports
- Configure departments

- Manage maintenance
- Generate QR Codes
- Export reports

Employee

Limited access.

Responsibilities

- View assigned assets
- Scan QR Code
- Raise maintenance requests
- Return assigned assets

Technician

Maintenance only.

Responsibilities

- View assigned tickets
- Update repair status
- Upload repair reports
- Close maintenance requests

Manager

Monitoring role.

Responsibilities

- View analytics
- Approve requests
- View department assets
- Export reports

3. Permissions

Admin

 Can

- Create assets
- Edit assets
- Delete assets
- Assign assets
- Manage users
- Generate QR
- View all reports
- Export data
- View all maintenance

 Cannot

None

Employee

 Can

- Login
- View own assets
- Scan QR
- Raise maintenance request
- Return asset

 Cannot

- Delete assets
- Edit company assets
- View other employee assets
- Access admin dashboard

Technician

 Can

- View maintenance tickets
- Accept repair job
- Update repair progress

- Close ticket

 Cannot

- Create assets

- Delete assets

- Assign assets

- Manage users

Manager

 Can

- View analytics

- Approve requests

- Export reports

 Cannot

- Delete assets

- Manage users

- Edit maintenance history

4. Authorization Matrix

| Feature | Admin | Manager | Technician | Employee |

|-----|:---:|:-----:|:-----:|:-----:|

Login	✓		✓		✓		✓	
Dashboard	✓		✓		✓		✓	
Add Asset	✓		✗		✗		✗	
Edit Asset	✓		✗		✗		✗	
Delete Asset	✓		✗		✗		✗	
Assign Asset	✓		✗		✗		✗	
Scan QR	✓		✓		✓		✓	
View Reports	✓		✓		✗		✗	
Export Reports	✓		✓		✗		✗	
Raise Ticket	✓		✗		✗		✓	
Update Ticket	✓		✗		✓		✗	
Manage Users	✓		✗		✗		✗	

5. Row-Level Security

Users should only access the data they are authorized to view.

Employees

Can only view

- Their assigned assets
- Their maintenance requests
- Their profile

Cannot view

- Other employees
- Other departments
- Company analytics

Technician

Can only view

- Assigned maintenance tickets
- Repair history for assigned assets

Cannot

- View salary
- User credentials
- Company financial reports

Managers

Can only view

- Department assets
- Department reports

Cannot

- Edit assets
- Delete assets

Admin

Can access all records.

6. Password Policy

Minimum Length

- 8 Characters

Must Include

- One uppercase letter
- One lowercase letter
- One number
- One special character

Examples

 Strong

...

Asset@2026

...

✖ Weak

...

12345678

password

admin

...

7. Session Management

Automatically logout after

- 30 minutes of inactivity

Token Expiration

- 24 hours

Refresh Token

- Automatically renew session

Logout

- Clears token

- Invalidates refresh token

8. API Security

Every protected API requires

...

Authorization: Bearer <JWT_TOKEN>

...

Example

```http

GET /api/assets

Authorization: Bearer eyJhbGc...

...

---

## ## Rate Limiting

Login

Maximum

...

5 Attempts / Minute

...

Search

...

60 Requests / Minute

...

AI Chat

...

20 Requests / Minute

...

---

## # 9. Database Security

Passwords

Stored using

...

bcrypt

...

Sensitive Data

Encrypted

Examples

- Email
- Phone Number
- Purchase Cost

- Vendor Details

Primary Keys

UUID

Never Sequential IDs

---

# 10. Error Handling

## Invalid Login

Message

...

Invalid email or password.

...

---

## Unauthorized Access

Status

...

403 Forbidden

...

Message

...

You do not have permission to access this resource.

...

---

## Expired Token

Status

...

401 Unauthorized

...

Message

...

Session expired. Please login again.

...

---

## Asset Not Found

Status

...

404 Not Found

...

Message

...

Requested asset does not exist.

...

---

## Server Error

Status

...

500 Internal Server Error

...

Message

...

Something went wrong.

Please try again later.

...

---

# 11. Edge Cases

The application should handle:

- Duplicate asset IDs
- Duplicate QR codes

- Invalid QR scans
- Network failure
- API timeout
- Token expiration
- Empty forms
- Invalid file upload
- Large images
- Simultaneous asset assignment
- Deleted users with assigned assets
- Maintenance ticket duplication

---

## # 12. Audit Logs

Every important activity is logged.

### Log Examples

- User Login
- Asset Created
- Asset Updated
- Asset Deleted
- QR Generated
- Asset Assigned
- Asset Returned
- Maintenance Started
- Maintenance Completed
- User Created
- Password Changed

Each log stores

- User ID
- Timestamp
- IP Address
- Device
- Action
- Previous Value
- New Value

---

### # 13. Future Security Enhancements

- Multi-Factor Authentication (MFA)
- Biometric Login
- Single Sign-On (SSO)
- Hardware Security Keys
- IP Whitelisting
- Device Trust Verification
- AI-based Anomaly Detection
- Automatic Account Locking
- Security Dashboard
- SIEM Integration

---

### # Security Summary

Authentication

- JWT

## Password Encryption

- bcrypt

## Authorization

- Role-Based Access Control (RBAC)

## Data Access

- Row-Level Security

## API Protection

- Bearer Token

## Audit Logging

- Enabled

## Rate Limiting

- Enabled

## HTTPS

- Mandatory

## Encryption

- Sensitive Data Encrypted

...

### ### Completed Documents

- \*\*Document 1:\*\* Product Requirements Document (PRD)
- \*\*Document 2:\*\* Security & Access Document

The next document will be **Frontend Specification Document**, where we'll define the complete design system: color palette, typography, component library, spacing rules, responsive layouts, page wireframes, icons, animations, and API integration details so every generated screen has a consistent look and feel.